

# Regra de Negócio: Permissões

docs/business-rules

Ciclartech · Plataforma de Gestão de Ativos Assistivos

# Permissões

---

## Objetivo

---

Consolidar, num único lugar, o que cada perfil pode fazer — para que qualquer funcionalidade nova seja avaliada contra esta tabela antes de ser implementada, em vez de decidida caso a caso na view.

## Regras de negócio

---

- **Owner:** acesso irrestrito à plataforma. Vê todos os clientes, contratos, métricas e planos. Não pertence a nenhum tenant. Único papel autorizado a usar consultas cross-tenant ( `all_tenants()` ), reforçado por teste de arquitetura.
- **Admin:** acesso total dentro do próprio tenant. Cadastra/edita/desativa unidades, cadastra Gestores/Funcionários, define permissões (unidades atribuídas), visualiza todos os ativos/empréstimos/unidades da organização.
- **Gestor:** acesso operacional pleno, restrito às unidades atribuídas a ele. Pode cadastrar ativos, emprestar, devolver, enviar/finalizar manutenção, cadastrar beneficiários, emitir relatórios, dar baixa, registrar extravio e recuperação, transferir ativo entre unidades, gerenciar usuários de nível igual ou inferior.
- **Funcionário:** acesso às operações do dia a dia, restrito às unidades atribuídas a ele — localizar ativos, emprestar, devolver, renovar, registrar fotos, consultar ativos, finalizar higienização, corrigir dados da manutenção em curso, imprimir etiquetas. Não altera configurações da organização, não cadastra/edita ativos, não gerencia usuários, não transfere ativo entre unidades.

## Matriz de permissões por ação

| Ação                                          | Funcionário | Gestor | Admin | Owner            |
|-----------------------------------------------|-------------|--------|-------|------------------|
| Consultar ativo / QR / timeline               | ✓           | ✓      | ✓     | ✓ (cross-tenant) |
| Emprestar / devolver / renovar                | ✓           | ✓      | ✓     | —                |
| Enviar / finalizar manutenção                 | ✓           | ✓      | ✓     | —                |
| Editar manutenção em curso                    | ✓           | ✓      | ✓     | —                |
| Cadastrar / editar ativo                      | —           | ✓      | ✓     | —                |
| Imprimir / reimprimir etiqueta                | ✓           | ✓      | ✓     | —                |
| Transferir ativo entre unidades               | —           | ✓      | ✓     | —                |
| Registrar extravio                            | —           | ✓      | ✓     | —                |
| Dar baixa em ativo                            | —           | ✓      | ✓     | —                |
| Registrar recuperação (extravio)              | —           | ✓      | ✓     | —                |
| Reativar ativo inativo                        | —           | —      | ✓     | —                |
| Cadastrar/gerenciar usuários (nível inferior) | —           | ✓      | ✓     | ✓                |
| Cadastrar/editar/desativar unidade            | —           | —      | ✓     | —                |
| Ver auditoria do tenant                       | —           | ✓      | ✓     | ✓ (cross-tenant) |
| Ver dados de outros tenants                   | —           | —      | —     | ✓                |

## Validações

- Toda ação de mutação de estado é revalidada no servidor ( `executar_acao` ), independente do que a UI mostra — um usuário não pode contornar a permissão manipulando a requisição.
- `owner_required` checa especificamente `is_platform_staff`, nunca `is_superuser` — as duas flags são independentes por decisão de projeto (superuser de Django Admin não implica acesso ao painel Owner).

## Casos de exceção

- Um Admin nunca é bloqueado por unidade — a regra "Admin vê tudo" é incondicional, independente de qualquer atribuição de unidade que porventura exista para ele.
- Além do nível hierárquico, toda ação sobre um ativo é limitada pelo **escopo de unidade** do usuário: um Gestor não opera ativo de unidade que não lhe foi atribuída, mesmo tendo o nível necessário para a ação. Ver `docs/business-rules/unidades.md`.
- Acesso fora do escopo de unidade responde **404** (não encontrado), não 403: confirmar a existência já entregaria a informação que o escopo protege.

- Falha de permissão em qualquer view sempre retorna `PermissionDenied` (403), nunca um redirecionamento silencioso que esconda o motivo.

## Impactos em outros módulos

---

Esta é a referência normativa usada por `ativos.md`, `emprestimos.md`, `manutencao.md`, `unidades.md` e `usuarios.md` — qualquer alteração de nível mínimo de uma ação deve ser refletida aqui primeiro.